Android 隐私一致性审计实验汇报

Lab2：Data Safety 与 Privacy Policy 自动比对

李禹江，张博涵，蒋兴宇

我的刀盾队

2026 年 3 月 30 日

目录

1. 实验背景与目标
2. 实验设置
3. 实验结果
4. 合规解释与讨论
5. 结论与改进

实验背景

- **实验任务**
  - 对比 Android 应用 `Data Safety` 与 `Privacy Policy`
  - 利用 LLM 自动识别合规风险标签
- **输出标签（三分类）**
  - `incorrect`：Data Safety 未声明，但隐私政策提到
  - `incomplete`：Data Safety 有声明，但细节不完整
  - `inconsistent`：两者都提到，但描述冲突
- **实验价值**
  - 构建“模型初筛 + 人工复核”的隐私审计流程
  - 将输出结果映射到你们既有 22 项合规框架

实验目标

- **目标 1：流程可复现**
  - 在 `example.csv` 上验证审计、后处理、评估全链路
- **目标 2：全量性能评估**
  - 在 `all_data_150.csv` 上产出 Precision/Recall/F1/Accuracy
- **目标 3：形成合规解释**
  - 给出典型误判样本与改进方案
  - 关联《个保法》22 项维度输出结论

环境与模型配置

- **运行环境**
  - OS：Windows（PowerShell）
  - Python：3.10（Conda 环境：`android_privacy_lab`）
- **核心依赖**
  - `transformers` / `torch` / `pandas` / `scikit-learn` / `matplotlib`
- **后端模式**
  - `local`（本地模型）、`deepseek`（API）、`mock`（快速验证）

关键命令（实际运行）

```
conda run -n android_privacy_lab python run_audit.py full \
  --provider deepseek \
  --input-csv data/all_data_150.csv \
  --groundtruth-csv data/all_data_150_groundtruth.csv \
  --raw-output-csv results/all_data_150_results_cli.csv \
  --processed-output-csv results/all_data_150_results_processed_cli.
      csv \
  --metrics-output-csv results/metrics_summary_all_data_150_cli.csv
      \
  --figures-dir results/figures_cli_all_data_150
```

数据与输出文件

类别	文件	用途
输入数据	data/example.csv / data/all_data_150.csv	审计输入
真值标签	example_groudtruth.csv / all_data_150_groundtruth.csv	评估基准
原始输出	results/*_results*.csv	包含原始 result 字段
后处理输出	results/*_processed*.csv	三类标签（0/1）
指标输出	results/metrics_summary*.csv	指标汇总

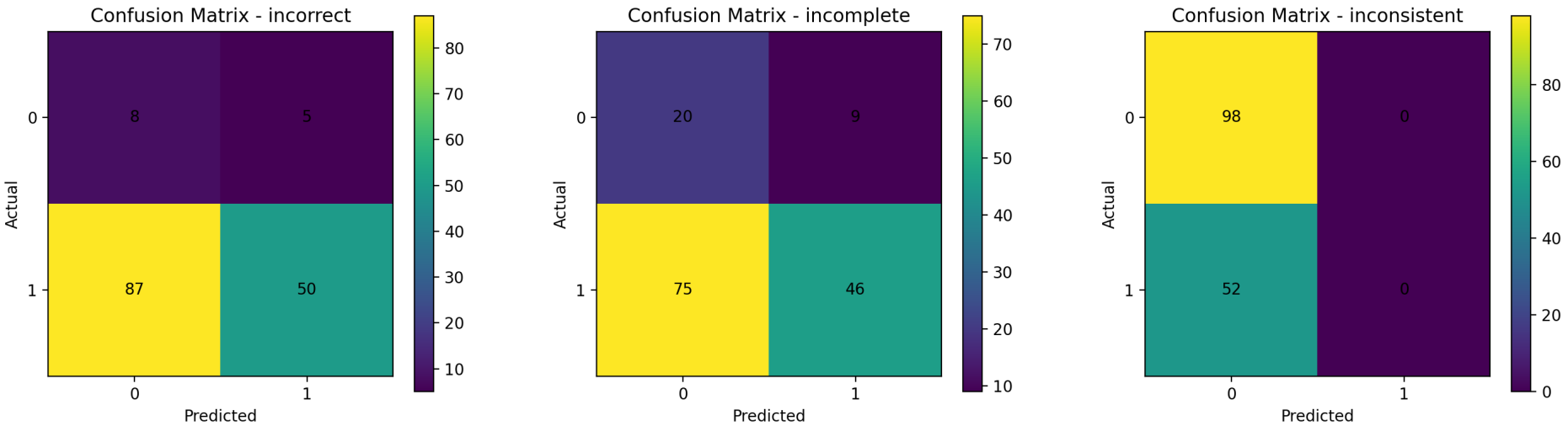
实验流程

1. 审计推理：生成 `result` JSON
2. 结果后处理：拆成三类标签列
3. 对齐真值：与 groundtruth 合并
4. 指标计算：Precision / Recall / F1 / Accuracy
5. 可视化与解释：混淆矩阵 + 合规分析

指标汇总（全量 150 样本）

标签	P	R	F1	Acc	说明
incorrect	0.909	0.365	0.521	0.387	精确率高但召回率低，漏检较多
incomplete	0.836	0.380	0.523	0.440	与 incorrect 相近，仍以漏检为主
inconsistent	0.000	0.000	0.000	0.653	未识别出正类冲突样本，需重点改进

混淆矩阵（全量 150 样本）



图源：`src/2-2/results/figures_cli_all_data_150`

典型样本分析

案例 1：误判样本

样本 ID：12（Employee Card Maker）；标签：`inconsistent`；真值：1；预测：0。
误判原因：Data Safety 与隐私政策的冲突表达较隐式，模型更偏向保守预测 0。

案例 2：正确样本

样本 ID：1（Text On Photo Photo Per Status）；预测与真值均为 (incorrect=1, incomplete=1, inconsistent=0)。
关键证据：Data Safety 几乎为空，但隐私政策明确提到数据共享与数据收集。

小结

模型对“显式缺失声明”识别较稳定；对“文本冲突”类型仍需人工复核。

标签到 22 项标准的映射

- `incorrect`：优先关联第 2、9、13、20 项（缺失声明风险）
- `incomplete`：保存期限、接收方信息、用户权利路径粒度不足
- `inconsistent`：重点核查跨境传输与第三方共享冲突
- 本实验结果与 Week2 结论部分一致：声明缺失更易检出，复杂冲突仍是主要难点

关键发现

- **发现 1**：`incorrect/incomplete` 均为高 Precision、低 Recall，说明“命中较准但漏检明显”
- **发现 2**：`inconsistent` 的 P/R/F1 为 0，表明当前模型对冲突语义识别能力不足
- **发现 3**：需结合混淆矩阵解读，不能仅依据 Accuracy 判断模型可用性
- **发现 4**：现阶段流程适合做合规初筛，不适合直接替代人工审计

实验结论

- 结论 1：实验流程在 150 条样本上可复现并稳定运行，输出结构完整可评估
- 结论 2：当前表现最佳标签为 `incomplete`（F1=0.523），最难标签为 `inconsistent`（F1=0）
- 结论 3：与 Week2 的 22 项研究结论部分一致：显式缺失较易识别，复杂合规冲突更难自动检测
- 结论 4：推荐采用“LLM 初筛 + 人工复核”的工程化方案

改进方向

- 模型：继续对比 Phi/Qwen/DeepSeek，并重点优化 `inconsistent` 标签
- Prompt：加入冲突判定 few-shot 样例，明确“矛盾表达”判断规则
- 数据：扩充冲突类样本并平衡标签分布，降低模型偏向负类的风险
- 工程：增加异常重试、JSON 校验与复核队列，形成稳定审计流水线

分工与复现说明

成员	模块	工作	产出
李禹江	运行与日志	跑通全流程命令	结果 CSV、日志
张博涵	评估与可视化	计算指标、绘制混淆矩阵	指标表、图表
蒋兴宇	合规分析	映射 22 项并撰写结论	发现与建议页

感谢聆听！

Q&A